Security Assessment for password

Objective:

The objective of this assessment was to evaluate the effectiveness of password security practices by implementing secure credential storage, generating high-entropy passwords, validating their usability in a live authentication scenario, and assessing the exploitability of weak credentials through brute-force techniques.

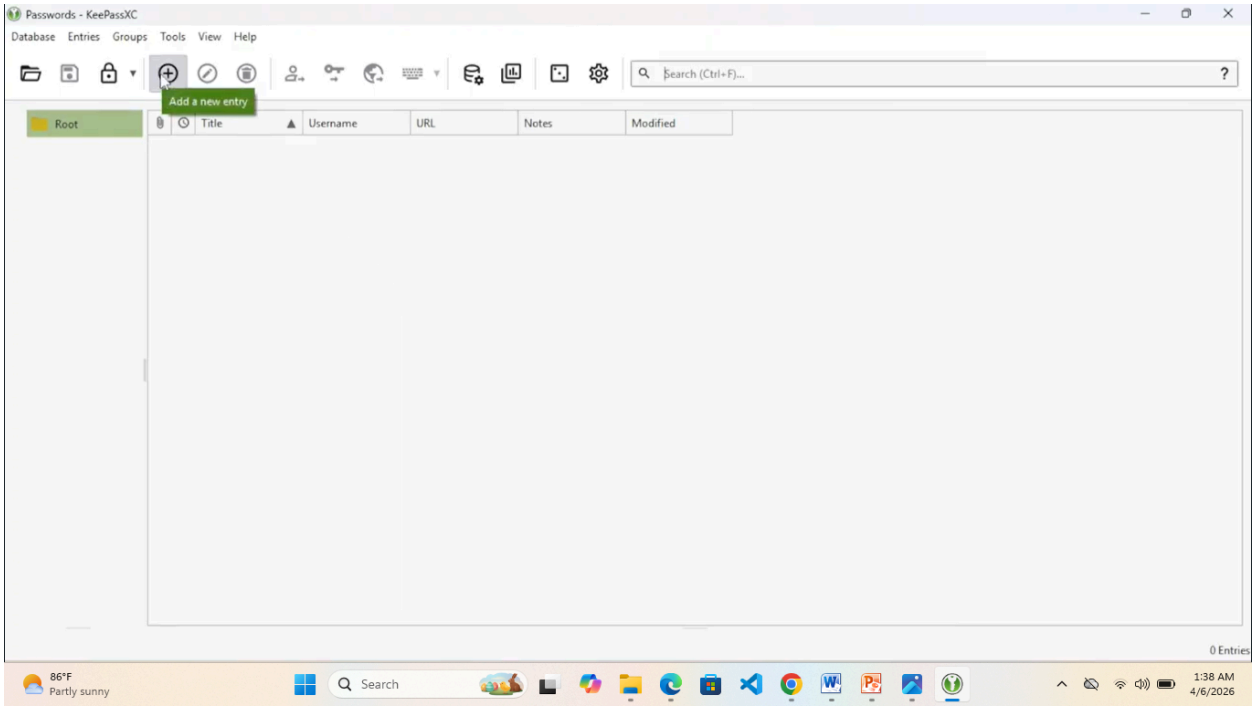
Methodology

The assessment was conducted in three phases: secure vault implementation, strong password validation, and weak password exploitation.

1. Secure Password Vault Implementation

A secure password vault was created using **KeePassXC** to ensure proper credential management. A new encrypted database (`SecureVault.kdbx`) was initialized and protected with a strong master password consisting of more than 16 characters, incorporating uppercase, lowercase, numeric, and special characters.

The successful creation and access of the vault confirm that sensitive credentials can be securely stored and managed in an encrypted environment resistant to unauthorized access.



2. Strong Password Generation and Audit

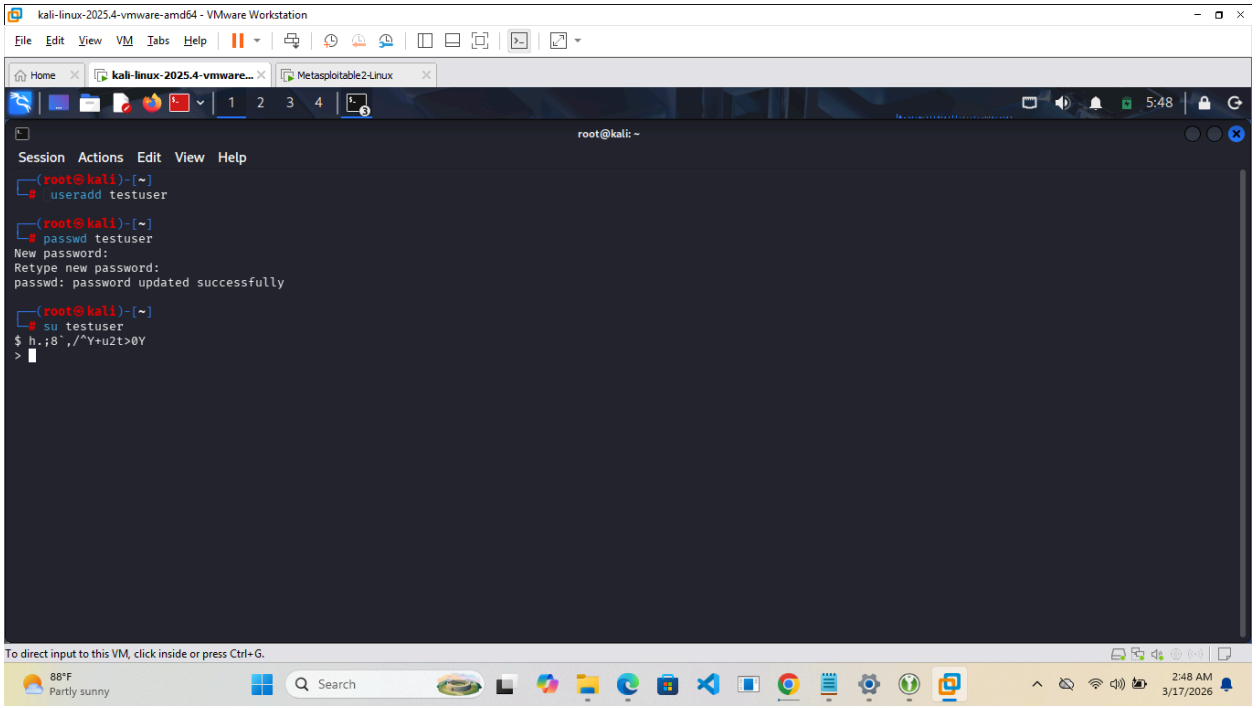
Using the built-in password generator within KeePassXC, a strict password policy was enforced to generate high-strength credentials. The configuration ensured:

- Minimum length of 16 characters
- Inclusion of uppercase and lowercase letters
- Integration of numbers and special symbols
- High randomness and entropy

Five unique passwords were generated based on these criteria and stored securely within the vault under a structured entry. The passwords exhibited no predictable patterns and met industry best practices for password security.

3. Strong Password Authentication Validation

To validate the effectiveness of the generated passwords, one credential was selected and used to authenticate into a controlled virtual machine environment. The login process was executed successfully without errors, confirming that strong passwords are both secure and operationally viable in real-world systems.



4. Weak Password Exploitation (Hydra Attack Simulation)

To evaluate the security risks associated with weak credentials, a controlled brute-force attack was conducted against the FTP service running on a Metasploitable2 target system.

Service Enumeration:

An initial scan was performed to verify the availability of the FTP service. The results confirmed that port 21 was open and accessible, indicating that the service was active and a viable target for authentication testing.

Attack Execution:

A Hydra brute-force attack was executed using a known weak credential combination. The tool was configured to target the FTP service with the username `admin` and the commonly used weak password `password123`. This simulated a real-world attack scenario where adversaries exploit predictable credentials.

Attack Monitoring:

During execution, Hydra systematically attempted authentication against the FTP service. The tool interacted with the target by sending repeated login requests and analyzing responses to determine credential validity.

Attack Outcome:

The attack successfully identified valid login credentials, confirming that the weak password `password123` is highly susceptible to brute-force attacks. This demonstrates how easily predictable passwords can be compromised using automated tools with minimal effort.

---

5. Findings:

Strong Password Security:

- KeePassXC provided secure, encrypted storage for credentials
- Generated passwords met high complexity and entropy standards
- Strong passwords functioned effectively in authentication scenarios

Weak Password Vulnerability:

- The weak password was successfully compromised using Hydra
- The attack required minimal time and computational effort
- Highlights a critical weakness in systems using predictable credentials

---

6. Risk Analysis:

The successful compromise of weak credentials represents a **critical security vulnerability**. Attackers leveraging automated tools can rapidly gain unauthorized access to systems, potentially leading to:

- Unauthorized system access
- Credential theft and reuse
- Privilege escalation
- Full system compromise

---

7. Recommendations:

To mitigate the identified risks, the following security measures are recommended:

- Enforce a minimum password length of 16+ characters
- Require complex password composition (uppercase, lowercase, numbers, symbols)

- Implement secure password managers such as KeePassXC
- Eliminate default and weak credentials across all systems
- Apply account lockout policies after repeated failed login attempts
- Enable multi-factor authentication (MFA) for enhanced security
- Conduct regular password audits and penetration testing

---

8. Conclusion:

This assessment highlights the significant disparity between strong and weak password practices. While strong passwords generated and managed through KeePassXC provide robust protection against unauthorized access, weak passwords remain a major vulnerability that can be easily exploited.